Unvalidated Redirects: Outdated Allowlist (OWASP Juice Shop)

Severity: Low — Context-dependent

1. Concept Overview

Unvalidated Redirects occur when an application redirects users to another URL without properly validating the destination.
In this OWASP Juice Shop challenge, the issue involves an Outdated Allowlist. The application previously supported cryptocurrency donations through Bitcoin, Dash, and Ether addresses. Although these donation addresses were no longer promoted, some references remained in the application's source code.
This challenge demonstrates how outdated references in application code can expose functionality that developers intended to remove.

2. Methodology — How I Solved the Lab

Step 1: Identify the challenge
Opened the OWASP Juice Shop Score Board and selected the Outdated Allowlist challenge.

Step 2: Inspect the application source
Used the browser's Developer Tools (Inspect) to examine the application's source code and searched for redirect-related references.

Step 3: Identify outdated redirect URLs
Located the previously used cryptocurrency donation addresses and their associated redirect references that remained in the application source.

Step 4: Access the redirect functionality
Used the discovered redirect URL through the Juice Shop application to access one of the outdated cryptocurrency donation destinations.

Step 5: Verify completion
Confirmed that the challenge was marked as solved on the OWASP Juice Shop Score Board.

3. Technical Explanation

The application contains a redirect mechanism that uses a destination URL supplied through the to parameter.
Example redirect structure: http://localhost:3000/redirect?to=<destination-URL>

http://localhost:3000/redirect?to=https:%2F%2Fblockchain.info%2Faddress%2F1AbKfgvw9psQ41NbLi8kufDQTezwG8DRZm

The potential security concern is that redirect destinations must be validated against a current, trusted allowlist. Outdated entries may leave unintended redirect functionality accessible.

4. Security Impact

An attacker could potentially misuse an application's trusted domain to redirect users to malicious or misleading external websites.

Possible risks include:

- **Phishing attacks:** Redirecting users to fraudulent login pages.
- **Trust abuse:** Making malicious destinations appear to originate from a legitimate application.
- **Social engineering:** Directing users to misleading websites.
- **Reputation damage:** Users may associate malicious redirects with the legitimate application.

5. Remediation

1. **Maintain updated allowlists:** Remove outdated and unnecessary redirect destinations.
2. **Validate redirect URLs:** Permit only explicitly approved destination URLs.
3. **Use server-side validation:** Never rely exclusively on client-side checks to validate redirect destinations.
4. **Avoid user-controlled redirects:** Prefer predefined destination identifiers instead of accepting arbitrary URLs.
5. **Remove unused functionality:** Delete obsolete redirect references, routes, and cryptocurrency donation links.
6. **Use safe fallback destinations:** Redirect users to a trusted internal page when the requested destination is invalid.

6. Result

Successfully completed the Outdated Allowlist challenge in OWASP Juice Shop by inspecting the application's source code using browser Developer Tools, identifying outdated cryptocurrency redirect references, and accessing the associated redirect functionality.
This exercise improved my understanding of URL redirection, outdated allowlists, client-side source-code inspection, and the security risks associated with improper redirect validation.
Key Learning: Applications should validate every redirect destination against an updated allowlist. Removing obsolete references and preventing unauthorized external redirects helps reduce phishing and trust-abuse risks.

7. Evidence to Include

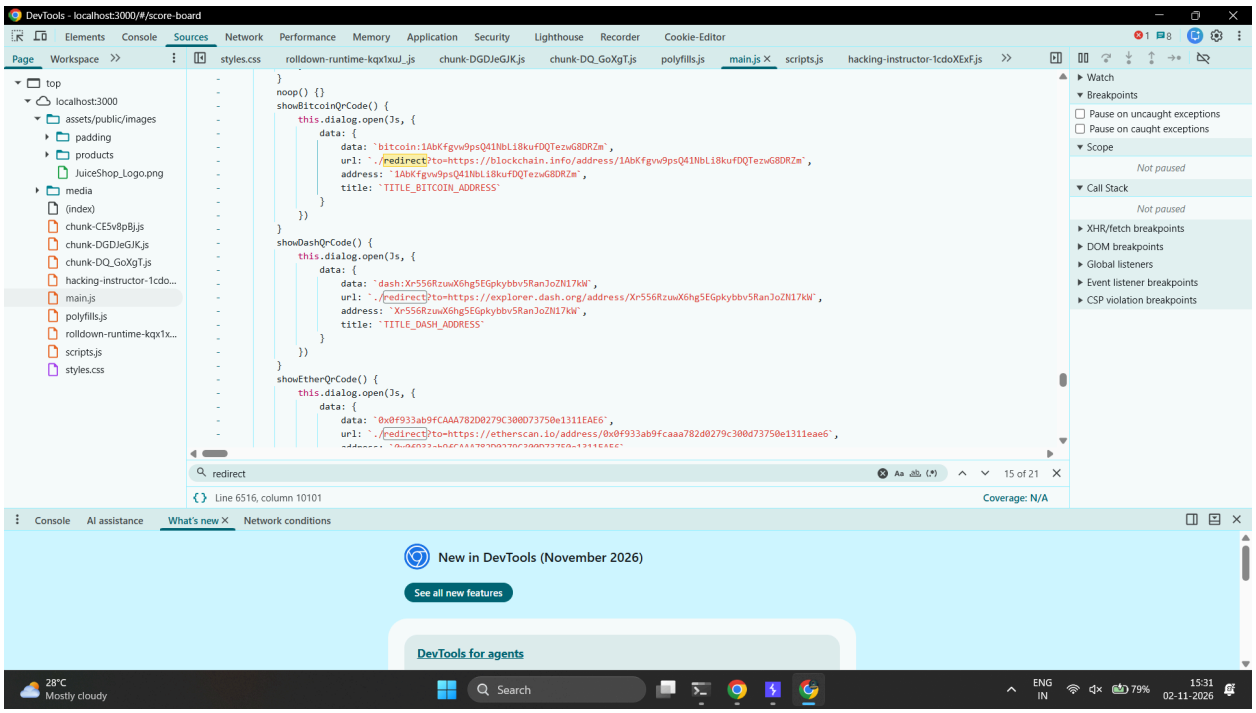


Figure 1: Browser Developer Tools discovered redirect references.

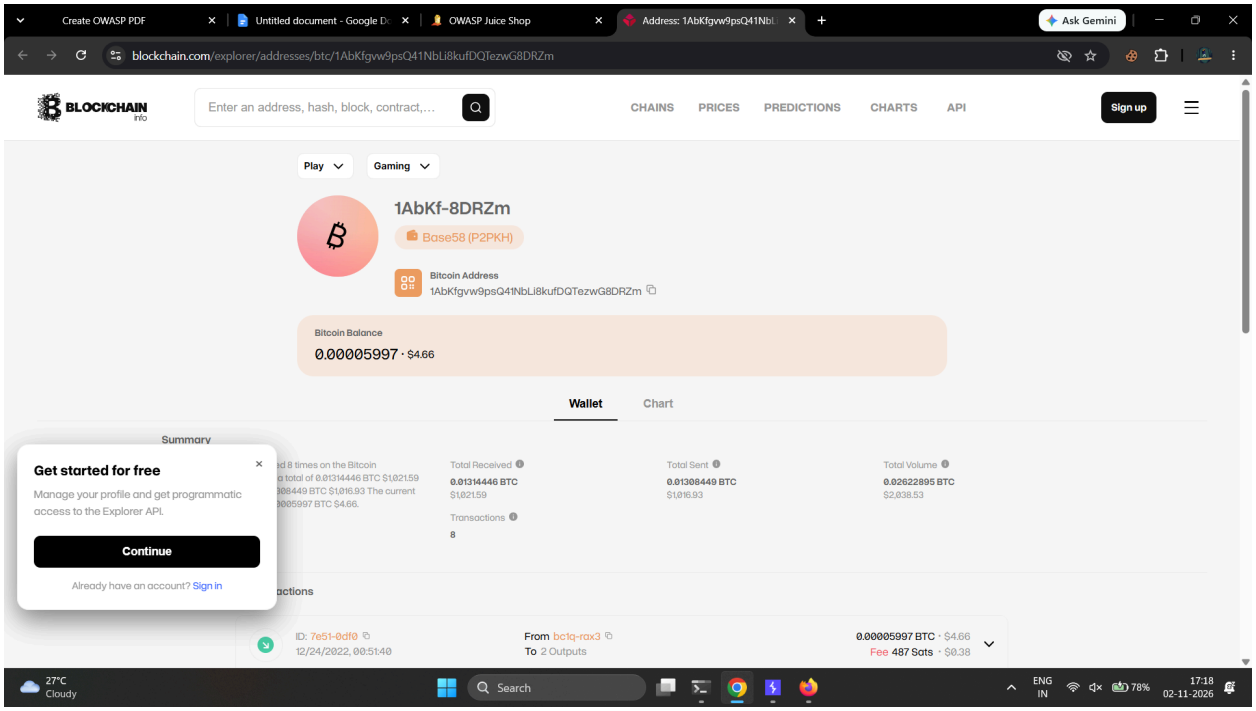


Figure 2: Redirect URL and destination identified outdated cryptocurrency destination.

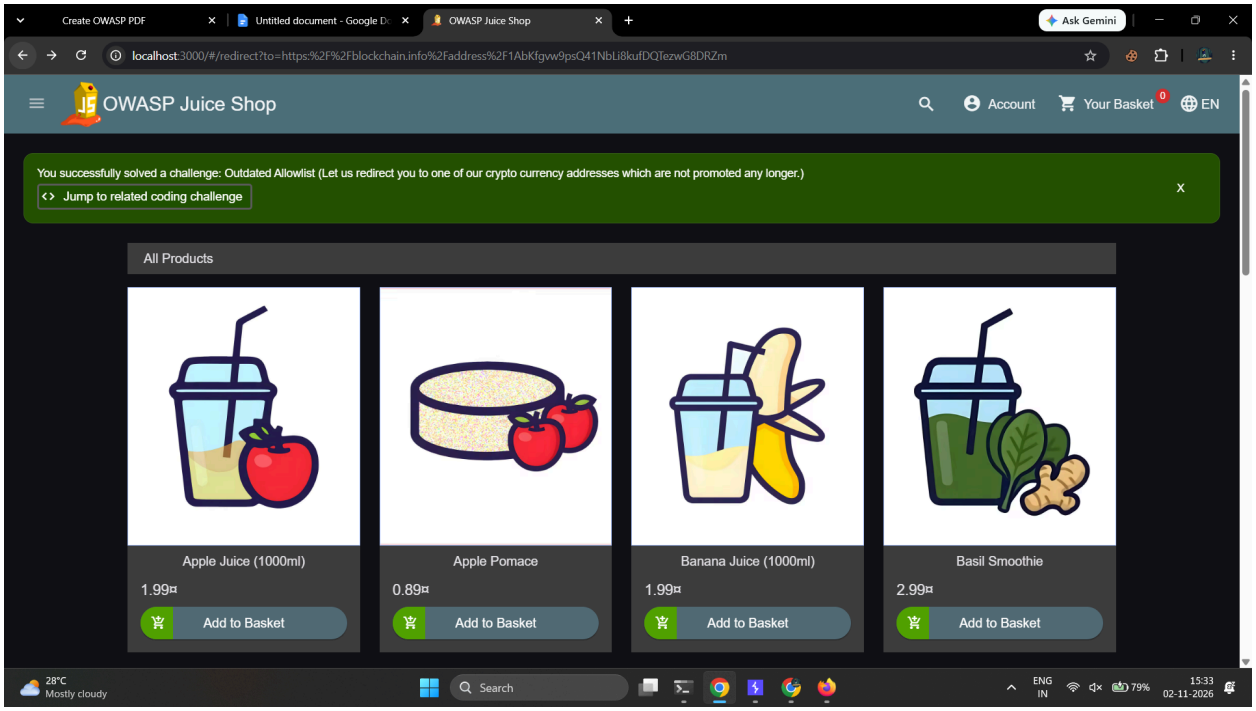


Figure 4: Score Board showing the challenge as completed.

References

- OWASP Juice Shop — Unvalidated Redirects
- OWASP — Unvalidated Redirects and Forwards Cheat Sheet

Suggested classification: Unvalidated Redirects — Outdated Allowlist.

Suggested severity: Low for this particular lab. Real-world severity depends on whether attackers can manipulate redirect destinations and the potential impact on users.

Outdated Redirect Allowlist (Code Fix)

Successfully completed Outdated Redirect and Fix It coding challenge in OWASP Juice Shop.

1. Fix Applied

The correct fix removes the three outdated cryptocurrency URLs from the redirectAllowlist while retaining the legitimate application URLs.
This ensures that obsolete cryptocurrency destinations are no longer treated as approved redirect targets.

2. Security Impact

Outdated allowlist entries can leave unintended redirect destinations available. Depending on the application and how users interact with its redirect functionality, this may create opportunities for phishing, social engineering, or misuse of the application's trusted domain.

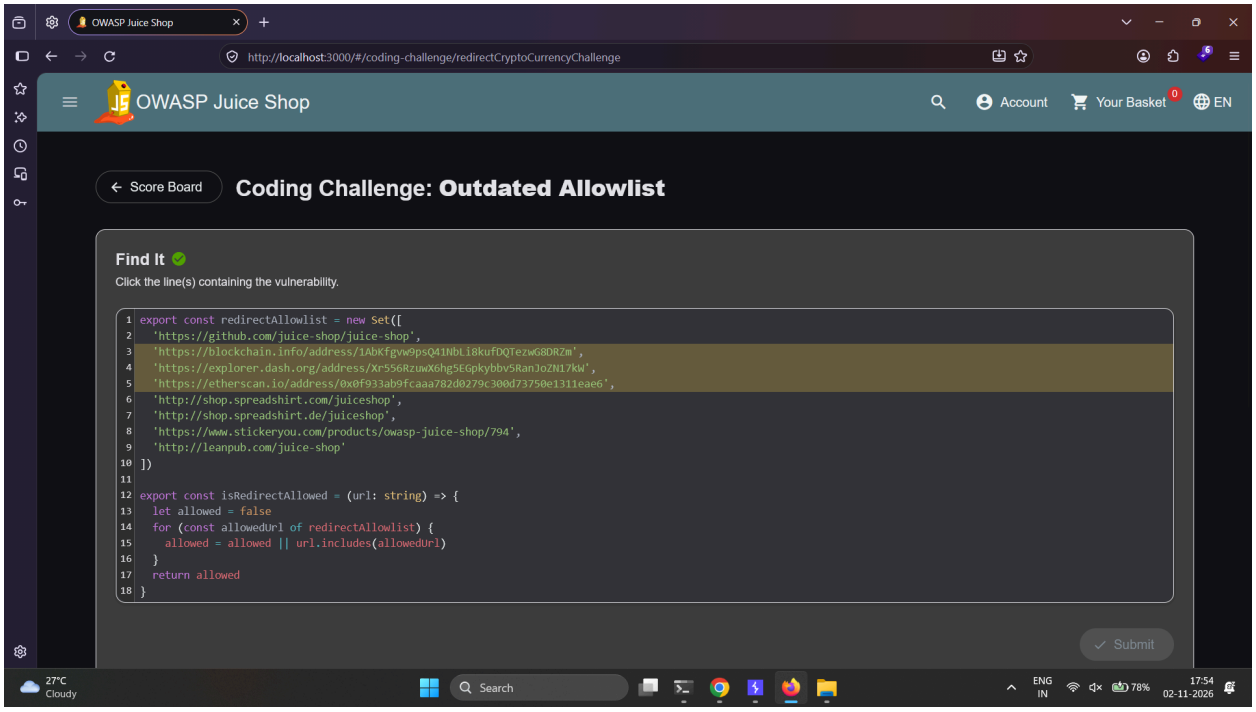
3. Remediation

- Regularly review and update URL allowlists.
- Remove deprecated or unused redirect destinations.
- Validate redirect destinations on the server side.
- Prefer predefined destination identifiers over accepting arbitrary URLs.
- Re-test redirect functionality after changes.

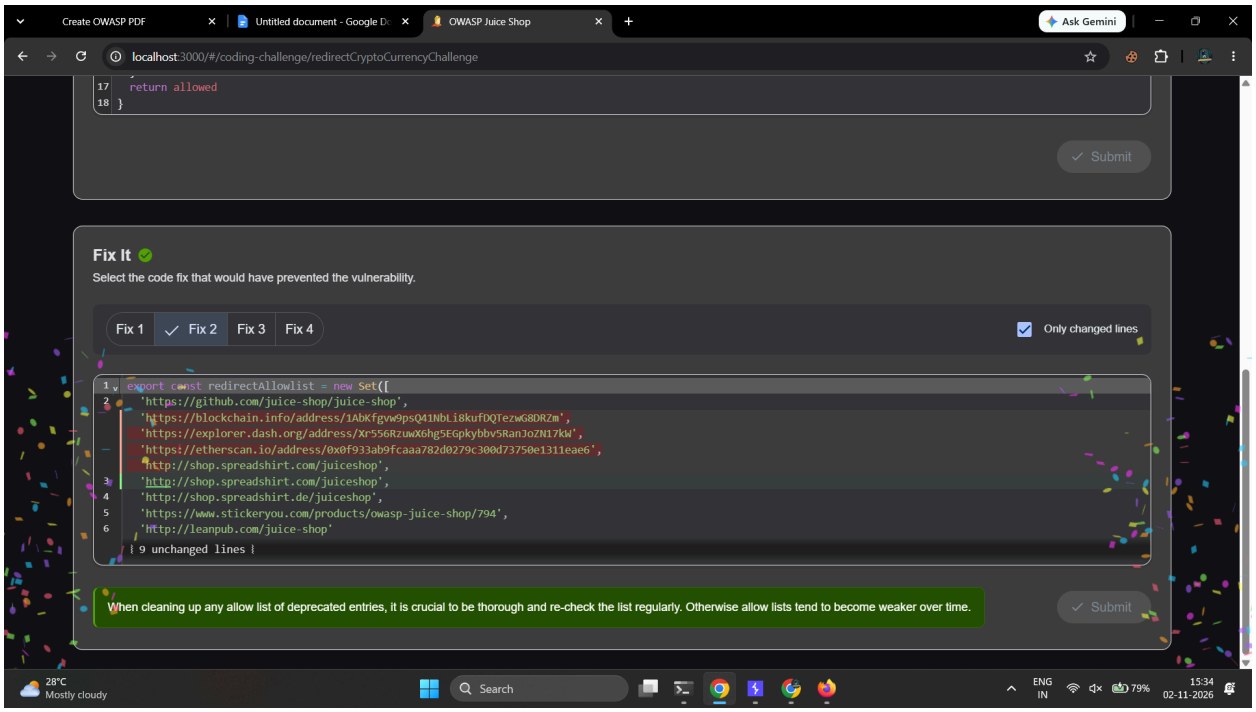
6. Result

Successfully completed both the Find It and Fix It stages of the OWASP Juice Shop coding challenge by identifying outdated cryptocurrency URLs and selecting Fix 2 to remove them from the allowlist.
Coding challenge completed

7. Evidence Screenshots



Screenshot 1: Initial Fix 1 selection (incorrect option).



Screenshot 2: Fix 2 selected, with the green success confirmation.

8. References

- OWASP Juice Shop – Unvalidated Redirects
- OWASP Unvalidated Redirects and Forwards Cheat Sheet

Documentation note: Keep this as a coding-fix exercise under Unvalidated Redirects → Outdated Allowlist. It demonstrates removal of obsolete trusted destinations; it does not by itself prove that arbitrary external URLs can be used for redirects.